

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Fri 10 Jul 2026, at 14:02:49

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=Medium, Confidence=High \(1\)](#)
 - [Risk=Low, Confidence=High \(1\)](#)
 - [Risk=Low, Confidence=Medium \(1\)](#)
- [Appendix](#)

- [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <http://localhost:8080>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: [User Confirmed](#), [High](#), [Medium](#), [Low](#), [False Positive](#)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk		User Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	1 (33.3%)	0 (0.0%)	0 (0.0%)	1 (33.3%)
	Low	0 (0.0%)	1 (33.3%)	1 (33.3%)	0 (0.0%)	2 (66.7%)
	Informational	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	1	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
Total		0 (0.0%)	2 (66.7%)	1 (33.3%)	0 (0.0%)	3 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Risk

		Informational		
		High (= High)	Medium (>= Medium)	Low (>= Low)
http://localhost:80		0	1	2
Site	80	(0)	(1)	(3)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	2 (66.7%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	3 (100.0%)
X-Content-Type-Options Header Missing	Low	1 (33.3%)
Total		3

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
-------	--------	------	-------------	-----------

Level	Reason	Site	Description	Statistic
Info	Informational	http://localhost:8080	Percentage of responses with status code 2xx	28 %
Info	Informational	http://localhost:8080	Percentage of responses with status code 4xx	71 %
Info	Informational	http://localhost:8080	Percentage of endpoints with content type application/json	33 %
Info	Informational	http://localhost:8080	Percentage of endpoints with content type text/html	66 %
Info	Informational	http://localhost:8080	Percentage of endpoints with method GET	100 %
Info	Informational	http://localhost:8080	Count of total endpoints	3

Alerts

Risk=Medium, Confidence=High (1)

http://localhost:8080 (1)

Content Security Policy (CSP) Header Not Set (1)

► GET http://localhost:8080/sitemap.xml

Risk=Low, Confidence=High (1)

http://localhost:8080 (1)

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

▼ GET http://localhost:8080/health

Alert tags

- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP 2017 A06](#)
- [WSTG-v42-INFO-02](#)
- [CWE-497](#)
- [OWASP 2025 A02](#)

Alert description

The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.

Request

▼ Request line and header section (235 bytes)

```
GET http://localhost:8080/health
HTTP/1.1
host: localhost:8080
user-agent: Mozilla/5.0 (Windows NT
10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/141.0.0.0
Safari/537.36
pragma: no-cache
```

cache-control: no-cache

▼ Request body (0 bytes)

Response

▼ Status line and header section (166 bytes)

HTTP/1.1 200 OK
Server: Werkzeug/3.0.3
Python/3.12.13
Date: Fri, 10 Jul 2026 08:28:55 GMT
Content-Type: application/json
Content-Length: 16
Connection: close

▼ Response body (16 bytes)

{"status": "ok"}

Evidence

Werkzeug/3.0.3 Python/3.12.13

Solution

Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.

Risk=Low, Confidence=Medium (1)

<http://localhost:8080> (1)

X-Content-Type-Options Header Missing (1)

► GET <http://localhost:8080/health>

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
--------	---

CWE ID	497
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers